AI-ENABLED CYBERSECURITY GOVERNANCE FRAMEWORK

Red Team / Blue Team Operational Policy for Advanced AI Models

Version 3.0 — Comprehensive Framework with Full Threat Landscape Coverage
Supersedes v2.0 — IAM-as-Primary-Defence Architecture

RESTRICTED — REGISTERED INDUSTRY PARTNERS ONLY

Classification	Restricted — Registered Industry Partners Only
Date	April 2026
Version	3.0 — Comprehensive Framework
Supersedes	v2.0 — IAM-as-Primary-Defence Architecture
Applies To	AI frontier model deployments in cybersecurity environments
Author	Ikshudhanva P L

V3.0 ADDITIONS — Known Threats Are Better Governed Than Unknown Ones
Section 11 — Supply Chain Identity Risk Section 12 — Federated Identity & Cross-Organisation Collaboration Section 13 — Quantum Cryptography Readiness Section 14 — Insider Threat

Detection Section 15 — AI Output Integrity Verification Section 16 — Regulatory & Jurisdictional Framework Section 17 — Digital Forensics & Evidence Preservation Section 18 — Continuous Compliance Monitoring Section 19 — Human Factors & Operational Resilience Section 20 — Agentic AI Controls

0. IAM as Primary Defence — The Foundational Thesis

Established in v2.0 and foundational to all subsequent sections. Traditional cybersecurity placed the firewall at the perimeter. Zero Trust redrew the map. This framework takes that principle further — treating IAM not as a supporting control but as the primary security architecture.

Domain	Requirement
Who can access	RBAC defines roles and structural permissions. No role, no access.
Under what conditions	ABAC enforces contextual gates — location, device, time, MFA freshness.
For how long	Just-in-Time access limits session duration. Roles expire. Elevation ends.
With what verification	FIDO2 hardware keys enforce phishing-resistant MFA. Identity is cryptographically hardware-bound.
With what oversight	PAM session recording captures every keystroke. WORM logs make the audit trail tamper-evident.
With what consequence	Separation of Duties, escalation chains, and automated lockdown are all triggered by identity events.

Core Thesis
IAM is not a module. It is the architecture. Every section of this framework is, at its core, an identity question.

1. Executive Summary

This framework establishes governance, access controls, operational procedures, and escalation protocols for deploying frontier AI models with advanced vulnerability detection and exploitation capabilities within cybersecurity environments.

Version 3.0 extends the framework to address the full known threat landscape — including supply chain risk, insider threats, quantum cryptography transition, agentic AI, and the human factors that technical controls alone cannot address. The governing philosophy of v3.0: known threats are better governed than unknown ones.

- Help, do not destroy — AI is a force multiplier for defenders, not a weapon.
- Human primacy — No AI action is terminal without human verification and authorisation.
- Transparency and accountability — Every action is logged, reviewed, and auditable.
- Complete threat coverage — Govern what you know before it becomes what you didn't.

2–10. Core Framework (v1.0 + v2.0 Rules Retained)

Retained from v2.0
Sections 2 through 10 — covering Scope and Applicability, Rules 1–7 (SoD, Virtual Environments,

> Test and Document Only, Access Controls, Blue Team Remediation, Critical Escalation, the Common Sense Principle), IAM Architecture Summary, and Model Version Control — are retained in full from v2.0. See v2.0 for complete specification of these sections.

11. Supply Chain Identity Risk

★ New in v3.0

The SolarWinds compromise demonstrated that the most sophisticated internal controls can be rendered irrelevant by a compromised upstream vendor.
[1]

An AI governance framework that governs internal operators but ignores the supply chain that delivers, maintains, and updates the AI model itself has a fundamental blind spot. Every third party with access to the AI model, its infrastructure, or its outputs is an identity risk that must be governed with the same rigour as internal operators.

11.1 Supply Chain Threat Vectors

Vector	Risk
AI Model Vendor	The organisation that trains and delivers the frontier AI model. If model weights are tampered with at source, all downstream controls are compromised.
Cloud Infrastructure Provider	The platform hosting the virtual environments. A compromised cloud provider has access below the governance layer.
Security Tool Vendors	PAM, SIEM, and audit logging vendors. A compromised logging vendor could silently suppress audit evidence.
Managed Service Providers	Third parties with privileged access to maintain or monitor components of the framework environment.
Software Dependencies	Libraries, packages, and tools used within the virtual environment. Open-source dependency compromise (e.g., XZ Utils) can create covert access.

[2]

11.2 Supply Chain IAM Controls

Domain	Requirement

[1] National Institute of Standards and Technology, "Cybersecurity Framework 2.0," NIST, February 2024, https://www.nist.gov/cyberframework.

[2] National Institute of Standards and Technology, "Zero Trust Architecture," NIST Special Publication 800-207, August 2020, https://doi.org/10.6028/NIST.SP.800-207.

Vendor Identity Verification	Every vendor with system access governed by the same RBAC/ABAC framework as internal operators. No vendor receives implicit trust.
Vendor Session Recording	All vendor remote access sessions recorded via PAM. No unrecorded vendor access permitted under any circumstance.
AI Model Provenance Verification	Cryptographic signature of AI model weights verified before each deployment. Signature chain traced to the AI vendor's root certificate.
Supply Chain SoD	No vendor may have access to both the AI model and the audit logs. Vendor access is siloed to its specific function.
Third Party Security Assessment	Vendors undergo security posture assessment before partnership and annually thereafter.
Vendor Offboarding Protocol	When a vendor relationship ends, all vendor identities are revoked immediately — treated as departing employee credentials under the JML leaver workflow.
Software Bill of Materials (SBOM)	A complete inventory of all software dependencies within the virtual environment is maintained and assessed for known vulnerabilities before each session.

11.3 Model Weight Integrity Protocol

- Model weights delivered via authenticated, encrypted channel from vendor
- Cryptographic hash of weights computed and registered with Governance Committee on delivery
- Hash verified against vendor-signed manifest before every deployment
- Any hash mismatch triggers immediate quarantine and vendor notification
- Independent third party verifies model behaviour against baseline after each deployment

12. Federated Identity & Cross-Organisation Collaboration

★ New in v3.0

Cybersecurity rarely happens in isolation. Vulnerability findings may require coordination with national CERTs, sector-specific ISACs, international partners, or the affected vendor. Each of these interactions creates an identity federation challenge: how do you share findings securely while maintaining the access controls that govern those findings?

12.1 Federation Standards

Standard	Use Case
SAML 2.0	Enterprise-to-enterprise identity federation for structured, long-term partner relationships.
OpenID Connect (OIDC)	Modern token-based federation for API-level integration with external

	partner systems.
FIDO2 Cross-Domain	Hardware key authentication that works across organisational boundaries without password sharing.
PKI Cross-Certification	Certificate authority cross-certification for high-assurance partner identity verification.

12.2 External Identity Controls

Domain	Requirement
Guest Operator Access	External parties receive time-limited, scope-restricted access only. Guest identities expire automatically at session end. No persistent external accounts.
External SoD	No external party may hold the VTO role. Translation of findings for external sharing performed exclusively by internal VTO.
Federated ABAC	External operator access subject to the same ABAC attribute checks as internal operators.
External Audit Trail	All external access logged separately with clear attribution to the external organisation and specific individual.
Data Minimisation for Sharing	Findings shared externally are further sanitised beyond the VTO Blue Team brief. Minimum information principle: share only what the external party needs to act.

12.3 Cross-Organisation Disclosure Protocol

1. Governance Committee approves external disclosure — no operator may share findings externally without approval
2. VTO produces external-grade sanitised brief — additional layer of sanitisation beyond Blue Team brief
3. Secure communication channel established — encrypted, authenticated channel to receiving organisation
4. Receiving organisation identity verified before sharing proceeds
5. Sharing logged with content hash — what was shared, to whom, when, and by whom
6. Follow-up verification — receiving organisation confirms receipt and confirms finding is under remediation

13. Quantum Cryptography Readiness

★ New in v3.0

This framework currently relies on PKI certificates, FIDO2/WebAuthn hardware keys, and HSM-signed audit logs — all of which use classical cryptographic algorithms theoretically vulnerable to

sufficiently powerful quantum computers. NIST finalised its first post-quantum cryptography standards in 2024 (FIPS 203, 204, 205), marking the beginning of the industry transition period. [3]

The threat of harvest now, decrypt later attacks means adversaries may be collecting encrypted session data today with the intention of decrypting it when quantum capability matures. [4]

For a framework with 7-year audit log retention, this is not a theoretical future risk. It is a present risk to historical records.

13.1 Cryptographic Inventory

Component	Current State & Migration Target
PKI Certificates	Currently RSA-2048 or ECDSA P-256. Quantum-vulnerable. Migration target: CRYSTALS-Dilithium (ML-DSA, FIPS 204).
Key Exchange	Currently ECDH. Quantum-vulnerable to Shor's algorithm. Migration target: CRYSTALS-Kyber (ML-KEM, FIPS 203).
Hash Functions	SHA-256/SHA-384. Grover's algorithm reduces effective security. Migration target: SHA-3/SHAKE (FIPS 205).
HSM-Signed Audit Logs	Signatures using classical algorithms. Priority migration target given 7-year retention window.
FIDO2/WebAuthn	Underlying cryptography quantum-vulnerable. Hardware key vendors publishing PQC roadmaps — monitor and upgrade on vendor timeline.

13.2 Migration Roadmap

Priority & Component	Target Timeline
Critical: Audit log signing	Migrate to ML-DSA within 12 months
High: PKI certificate infrastructure	Hybrid classical + PQC within 18 months. Full PQC within 36 months.
High: Key exchange for session encryption	ML-KEM hybrid mode within 18 months
Medium: FIDO2 hardware keys	Monitor vendor PQC roadmap. Upgrade on availability.
Medium: TLS inter-component	TLS 1.3 with PQC cipher suites within 24 months

[3] Google Project Zero, "Vulnerability Disclosure FAQ," Google, 2021, https://googleprojectzero.blogspot.com/p/vulnerability-disclosure-faq.html.

[4] FIRST.org, "Common Vulnerability Scoring System v4.0: Specification Document," FIRST, November 2023, https://www.first.org/cvss/v4.0/specification-document.

Lower: Internal hash functions	SHA-3 migration within 36 months

13.3 Hybrid Cryptography Period

During the transition period, hybrid cryptography — running classical and post-quantum algorithms simultaneously — is mandatory. This ensures communications are protected against both classical and quantum attacks during the migration window.

> **Governance Note**
> The Governance Committee must receive a quarterly quantum readiness update from the System Administrator until full PQC migration is complete.

14. Insider Threat Detection

★ New in v3.0

Section 6.4 addresses the scenario where an operator identity is externally compromised. This section addresses the distinct and arguably more dangerous scenario: the authorised insider who is actively working against the framework. Separation of Duties prevents collusion between teams but does not detect a solo insider who is authenticated, authorised, and deliberately misusing their access.

14.1 Behavioural Baseline & Anomaly Detection

Domain	Requirement
Behavioural Baseline	Normal operator activity patterns established during onboarding and refined over first 30 days, covering typical query types, session duration, finding volumes, and access patterns.
Query Anomaly Detection	Queries that significantly deviate from operator's role scope or historical patterns trigger automated review flag.
Access Pattern Monitoring	Unusual finding access patterns — accessing findings outside own session, accessing VTO outputs without authorisation — trigger alert.
Volume Anomalies	Significant deviation from typical output volumes flagged for review.
After-Hours Access Attempts	Any access attempt outside approved session schedule automatically logged as anomaly and reviewed by Governance.
UEBA Integration	User and Entity Behaviour Analytics platform correlates behavioural signals across all monitored dimensions with machine learning baseline.

[5]

[5] FIDO Alliance, "FIDO2: WebAuthn & CTAP," FIDO Alliance, 2023, https://fidoalliance.org/fido2/.

14.2 Canary Finding Protocol

Canary findings are deliberately fabricated vulnerability reports embedded within the legitimate findings pool. They are indistinguishable from real findings to any operator who should not have access to them. If a canary finding appears in an external context, it provides definitive proof of insider leakage and identifies the access point.

- Canary findings created by Governance Committee — never by Red or Blue Team operators
- Canary content is sufficiently realistic to be actionable if leaked but references non-existent components
- Canary access logged with the same granularity as real findings — any canary access outside authorised scope is an immediate alert
- Canary seeding frequency and placement is known only to Governance Committee and CISO

14.3 Deterrence Controls

Domain	Requirement
Formal Acknowledgement	Operators formally acknowledge monitoring at every session start. Psychological deterrence is a meaningful control.
Personnel Security Re-Vetting	All operators undergo personnel security re-vetting every 12 months.
Rotation Policy	Operators rotated between projects on a maximum 18-month cycle.
Reporting Culture	Operators actively encouraged to report colleague behaviour that seems inconsistent with the framework, protected under the whistleblower framework.

15. AI Output Integrity Verification

★ New in v3.0

This framework extensively governs who accesses the AI and what the AI is permitted to do. This section addresses whether the AI's outputs can be trusted. Three distinct integrity risks exist: hallucination (the AI generates plausible but false findings), adversarial prompting (a malicious operator manipulates the AI), and tampering (AI outputs are modified after generation and before review).

15.1 Cryptographic Output Integrity

Domain	Requirement
Generation-Time Signing	Every AI output is cryptographically signed at the moment of generation using the AI model service account's private key. Any post-generation modification is detectable.

Hash Chain Logging	Outputs are linked in a hash chain — each output's hash includes the previous output's hash. Retroactive modification of any output breaks the chain.
Tamper-Evident Transmission	Outputs transmitted from AI to human reviewer via authenticated, integrity-verified channel.
Immutable Finding Registry	All signed outputs registered in the WORM audit log immediately. Original signed version is the authoritative record.

15.2 Hallucination Detection Protocol

- Every finding must reference a verifiable, identifiable component — system name, software version, configuration identifier. Findings without specific component attribution are automatically flagged for mandatory human review
- Critical and High severity findings require independent human expert verification before entering the VTO pipeline
- Cross-model verification for Critical findings — a second independent AI instance reviews the finding without knowledge of the first model's output; significant divergence triggers escalated human review
- Historical finding pattern analysis — findings that significantly deviate from the AI model's historical patterns for similar system types are flagged as potential anomalies

15.3 Adversarial Prompt Detection

- All operator queries logged in full — the complete query, not a summary, is recorded with the session log
- Query content analysis — automated screening for patterns associated with prompt injection, jailbreaking, or scope manipulation
- Scope deviation alerts — queries referencing systems, topics, or objectives outside the operator's approved session scope trigger immediate alert
- AI refusal logging — instances where the AI declines to respond are logged as potential indicators of adversarial interaction

16. Regulatory & Jurisdictional Framework

★ New in v3.0

A vulnerability found in a system in Country A, by an organisation in Country B, using an AI model from Company C, affecting users in Country D — which law applies? This section provides a structured regulatory map.

16.1 Regulatory Disclosure Timeline Map

Jurisdiction / Framework	Reporting Timeline
India — CERT-In	6 hours for initial report. 30 days for detailed report.

India — DPDP Act 2023	As soon as practicable. Specific timeline pending subordinate legislation.
India — RBI Cyber Security Framework	2–6 hours depending on severity. Immediate for critical infrastructure.
EU — NIS2 Directive	24 hours initial notification. 72 hours detailed report.
EU — GDPR	72 hours to supervisory authority. Without undue delay to affected individuals.
US — SEC Cybersecurity Rules	4 business days after determining incident is material.
Global — Responsible Disclosure	90 days standard (Google Project Zero benchmark). Accelerated for active exploitation or life-safety risk.

678910

16.2 Jurisdictional Conflict Resolution

- Most restrictive timeline applies — if CERT-In requires 6 hours and NIS2 requires 24 hours, the 6-hour obligation governs for the overlapping scope
- Parallel notification — where multiple regulators have jurisdiction, notifications are prepared and transmitted in parallel, not sequentially
- Legal counsel engaged at discovery — for any finding with multi-jurisdictional implications, legal counsel is engaged at the point of discovery, not at the point of disclosure
- Safe harbour documentation — good faith compliance efforts documented from the moment of discovery

16.3 Authorised Computer Access Verification

All AI-assisted vulnerability testing must operate within explicitly authorised scope.

> **Legal Boundary**
> Testing systems beyond explicitly authorised scope — regardless of defensive intent — constitutes unauthorised computer access under India's IT Act Section 43, UK Computer Misuse Act, US CFAA, and equivalent legislation globally. Ignorance of scope boundaries is not a legal

[6] International Organization for Standardization, "ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection," ISO, 2022, https://www.iso.org/standard/27001.

[7] European Parliament and Council of the European Union, "General Data Protection Regulation (EU) 2016/679," Official Journal of the European Union L 119 (May 2016): 1–88, https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32016R0679.

[8] European Parliament and Council of the European Union, "Directive (EU) 2022/2555 on Measures for a High Common Level of Cybersecurity across the Union (NIS2 Directive)," Official Journal of the European Union L 333 (December 2022): 80–152.

[9] Indian Computer Emergency Response Team (CERT-In), "Directions under sub-section (6) of Section 70B of the Information Technology Act, 2000 relating to information security practices, procedure, prevention, response and reporting of cyber incidents," Ministry of Electronics and Information Technology, Government of India, April 2022, https://www.cert-in.org.in/Directions70B.jsp.

[10] Cybersecurity and Infrastructure Security Agency (CISA), "Alert (AA20-352A): Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations," CISA, December 17, 2020, https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a.

defence.

17. Digital Forensics & Evidence Preservation

★ **New in v3.0**

This framework produces extensive audit logs, session recordings, and findings documentation. These records may ultimately be required as evidence in criminal prosecutions, civil litigation, or regulatory investigations. A log that is technically intact but lacks forensic chain of custody is potentially inadmissible.

17.1 Chain of Custody

Domain	Requirement
Custody Initiation	Chain of custody documentation begins at session start — not at the point an incident is identified. Every session is treated as potentially evidentiary from its inception.
Custodian Designation	Each log and finding has a designated custodian responsible for its integrity. Custodian changes are logged with timestamp and reason.
Access Logging	Every access to an evidentiary record — including read access — is logged.
Integrity Verification	Hash of each evidentiary record computed at creation and verified at each access. Hash mismatch terminates access and triggers immediate Governance alert.
Transfer Protocol	Transfer of evidentiary records between custodians requires written acknowledgement, hash verification, and Governance Committee notification.

[11]

17.2 Forensic Standards Compliance

- ISO/IEC 27037 — Guidelines for identification, collection, acquisition, and preservation of digital evidence
- ISO/IEC 27041 — Guidance on assuring suitability and adequacy of incident investigative methods
- NIST SP 800-86 — Guide to integrating forensic techniques into incident response
- All forensic imaging uses write-blocking to prevent modification of original media
- Forensic images verified by MD5 and SHA-256 hash comparison against source

[11] National Institute of Standards and Technology, "Post-Quantum Cryptography: FIPS 203, 204, 205," NIST, August 2024, https://www.nist.gov/pqcrypto.

17.3 Evidence Lifecycle

Domain	Requirement
Retention Period	Standard retention: 7 years. Extended to indefinite for records associated with ongoing litigation, regulatory investigation, or criminal proceeding.
Preservation Hold	When litigation is reasonably anticipated, a legal hold is placed on all potentially relevant records. Scheduled deletion is suspended for held records.
Secure Destruction	At end of retention period, records destroyed using NIST SP 800-88 compliant methods. Destruction is logged and the destruction log itself retained for 3 years.

18. Continuous Compliance Monitoring

★ New in v3.0

A governance framework reviewed quarterly is a framework that may be non-compliant for up to three months before anyone notices. Continuous compliance monitoring creates a real-time view of framework health — turning periodic snapshots into a continuous signal.

18.1 Automated Control Testing

Domain	Requirement
RBAC Assignment Verification	Daily automated check confirms all active operator role assignments are current, approved, and consistent with the role definitions in Section 6.1.
ABAC Attribute Freshness	Real-time monitoring of ABAC attribute validity. Expired location verification, lapsed MFA, or unregistered device triggers immediate access denial and alert.
Certificate Validity Monitoring	Automated alerting when any certificate approaches expiry — 30 days, 14 days, and 7 days before expiry.
Session Recording Confirmation	At session start, automated check confirms session recording is active before any AI query is accepted. Recording failure is a hard block.
WORM Log Integrity Check	Daily automated hash verification of all audit log entries. Any integrity failure triggers immediate Governance alert.
Access Review Currency	Automated check that periodic access reviews have been completed within required timeframes.

18.2 Key Risk Indicators (KRIs)

KRI	Alert Threshold

Session Log Completeness	Below 100% — any incomplete session is an immediate alert
MFA Failure Rate	More than 3 failures per operator in 7 days — review required
Access Request Turnaround	More than 4 hours — escalate to Governance
Finding-to-Patch Cycle Time	More than 30 days for Critical findings — mandatory escalation
Canary Access Events	Any single event — immediate insider threat investigation
Vendor Session Coverage	Below 100% PAM recording — any unrecorded vendor session is an immediate alert

18.3 Benchmarking Standards

Framework controls are benchmarked annually against the following recognised standards:

- NIST Cybersecurity Framework (CSF) 2.0 — Identify, Protect, Detect, Respond, Recover
- ISO/IEC 27001:2022 — Information Security Management System
- CIS Controls v8 — Prioritised cybersecurity best practices
- NIST AI Risk Management Framework (AI RMF) — AI-specific governance
- India CERT-In Guidelines — Regulatory compliance baseline

[12][13][14][15]

19. Human Factors & Operational Resilience

★ New in v3.0

Every technical control in this framework is ultimately operated by humans. Cognitive overload, decision fatigue, stress, and psychological pressure all degrade the quality of human judgement — and human judgement is the ultimate safeguard in this framework at every critical decision point.

19.1 Operator Certification Requirements

Domain	Requirement
Technical Qualification	Operators must demonstrate technical competency in IAM, cybersecurity fundamentals, and the specific AI tool deployed. Competency assessed before first session and annually.

[12] Andres Freund, "Backdoor in Upstream xz/liblzma Leading to SSH Server Compromise," OpenWall, March 29, 2024, https://www.openwall.com/lists/oss-security/2024/03/29/4.

[13] International Organization for Standardization, "ISO/IEC 27037:2012 — Guidelines for Identification, Collection, Acquisition and Preservation of Digital Evidence," ISO, 2012.

[14] National Institute of Standards and Technology, "Artificial Intelligence Risk Management Framework (AI RMF 1.0)," NIST AI 100-1, January 2023, https://doi.org/10.6028/NIST.AI.100-1.

[15] Center for Internet Security, "CIS Controls Version 8," CIS, May 2021, https://www.cisecurity.org/controls/v8.

Psychological Fitness Assessment	Initial psychological fitness assessment by qualified occupational psychologist. Re-assessment triggered by significant life events.
Framework Induction	Mandatory structured induction covering all framework rules, escalation procedures, and ethical principles. Induction assessment required before any operational access.
Ongoing Training	Mandatory training updates when framework is materially updated. Quarterly security awareness refresher for all operators.

19.2 Fatigue & Cognitive Load Management

Domain	Requirement
Session Duration Limit	Maximum 4-hour continuous session. No operator may conduct more than 2 sessions in a 24-hour period, or more than 8 sessions in a 7-day period.
Mandatory Break Protocol	Sessions exceeding 2 hours require a documented 15-minute break. Operator must step away from the session room. Break is logged.
Complex Finding Protocol	Findings assessed as Critical severity trigger a mandatory 30-minute review period before any operator action. Prevents rushed decision-making on highest-stakes findings.
Cognitive Load Monitoring	Session complexity is tracked. If a single session produces an unusually high volume of findings, the session is paused for human review before continuing.

19.3 Psychological Safety & Error Management

- Near-miss reporting — operators explicitly encouraged to report situations where the framework was nearly violated. Near-misses treated as valuable intelligence, not disciplinary triggers.
- Error response protocol — when an operator makes an error within the framework, the default response is a structured review to understand root cause, not punitive action.
- Mandatory post-incident debrief — after any Red Alert event, all involved operators participate in a structured debrief focused on learning, not blame.
- Stress reporting channel — operators experiencing significant personal stress have a confidential channel to self-report and request temporary suspension of operational duties without career consequence.

19.4 Succession & Single Point of Failure Prevention

- Every designated role — VTO, Red Team Lead, Blue Team Lead, Governance Chair — must have a trained, currently authorised backup
- Backup operators exercised at least quarterly — they execute real session responsibilities under supervision
- Key person risk register maintained by Governance Committee — identifies roles where single-person dependency exists and tracks mitigation progress
- Critical process knowledge must be documented, not held only in individuals' heads. Documentation reviewed for accuracy every 6 months

20. Agentic AI Controls

★ New in v3.0 — The Most Forward-Looking Section

This framework was originally designed for a query-response AI interaction model: a human operator submits a query, the AI responds, a human reviews the output. The emergence of agentic AI fundamentally changes this dynamic. Agentic AI can plan multi-step tasks, execute sequences of actions autonomously, and adapt its approach based on intermediate results — all without a human query at each step.

In a cybersecurity context, an agentic AI could autonomously chain vulnerability discovery steps, adapt its approach based on what it finds, and produce exploit chains of a sophistication that exceeds what any query-response interaction could achieve. The governance controls for query-response AI are necessary but not sufficient for agentic AI.

20.1 Agentic Action Taxonomy

Action Class	Description & Status
Permitted Autonomous	Single-step analysis within predefined scope. Information gathering. Vulnerability classification. Status: Yes — logged.
Conditionally Permitted	Multi-step analysis chains up to 5 steps. Intermediate findings review. Scope-bounded exploration. Status: Yes — with mandatory human checkpoint at step 3.
Requires Approval	Action chains exceeding 5 steps. Novel methodology not in session brief. Findings suggesting critical severity. Status: Human approval required before continuation.
Prohibited	Any action with external network reach. System modification of any kind. Credential access or manipulation. Actions outside approved virtual environment. Status: Never — hard technical block.

20.2 Action Chain Controls

Domain	Requirement
Maximum Autonomous Steps	No agentic action chain may exceed 5 steps without a mandatory human checkpoint. At checkpoint, operator reviews intermediate findings and explicitly approves continuation.
Reversibility Requirement	Agentic AI may only take actions that are reversible within the virtual environment. Any action that cannot be undone by environment rollback is prohibited.
Scope Boundary Enforcement	Technical controls prevent agentic AI from accessing systems, files, or network segments outside its approved session scope. Attempted boundary violations trigger session suspension.
Action Velocity Limiting	Rate limiting on agentic action sequences. Unusually rapid action chains trigger automatic session suspension pending human review.

Goal Alignment Verification	Before initiating an agentic task, the AI model must articulate its planned approach and objective. Divergence between stated plan and actual actions is an alert trigger.

20.3 Agentic Identity

Domain	Requirement
Agentic Service Identity	A separate service account identity is provisioned for agentic AI operations, with more restricted permissions than the query-response identity.
Agentic Session Logging	Every autonomous action is logged under the agentic service identity with full action detail, preceding context, and outcome.
Agentic Identity Suspension	The agentic service identity can be independently suspended without affecting query-response capabilities.
Human Override Priority	At any point during an agentic session, any authorised operator can issue a halt command that immediately terminates all autonomous action. The halt is logged with operator identity and reason.

20.4 Kill Switch Protocol

The existence of an effective, reliably triggerable kill switch is non-negotiable for any agentic AI deployment. The kill switch must be:

- Immediately accessible to any authorised operator in the session room — physical and software-based mechanisms
- Effective within 5 seconds of activation — technical architecture must guarantee this
- Independently tested monthly — kill switch effectiveness is a continuous compliance check (Section 18)
- Non-bypassable by the AI — the kill switch operates at the infrastructure layer, not the application layer. The AI cannot disable its own kill switch
- Logged on every activation — kill switch use is always recorded regardless of reason

> **Agentic AI Principle**
> An AI that can act autonomously requires governance that assumes it will. Design controls for the worst credible autonomous behaviour, not the expected behaviour. The kill switch is not a last resort — it is a primary control that should be used without hesitation whenever autonomous behaviour diverges from intent.

21. References

The following authoritative sources inform this framework. Citations follow the Chicago Manual of Style (17th edition).

1. National Institute of Standards and Technology, "Cybersecurity Framework 2.0," NIST, February 2024, https://www.nist.gov/cyberframework.

2. National Institute of Standards and Technology, "Zero Trust Architecture," NIST Special Publication 800-207, August 2020, https://doi.org/10.6028/NIST.SP.800-207.
3. Google Project Zero, "Vulnerability Disclosure FAQ," Google, 2021, https://googleprojectzero.blogspot.com/p/vulnerability-disclosure-faq.html.
4. FIRST.org, "Common Vulnerability Scoring System v4.0: Specification Document," FIRST, November 2023, https://www.first.org/cvss/v4.0/specification-document.
5. FIDO Alliance, "FIDO2: WebAuthn & CTAP," FIDO Alliance, 2023, https://fidoalliance.org/fido2/.
6. International Organization for Standardization, "ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection," ISO, 2022, https://www.iso.org/standard/27001.
7. Indian Computer Emergency Response Team (CERT-In), "Directions under sub-section (6) of Section 70B of the Information Technology Act, 2000 relating to information security practices, procedure, prevention, response and reporting of cyber incidents," Ministry of Electronics and Information Technology, Government of India, April 2022, https://www.cert-in.org.in/Directions70B.jsp.
8. Ministry of Law and Justice, Government of India, "The Information Technology Act, 2000 (Act 21 of 2000)," Gazette of India, June 2000, as amended by the Information Technology (Amendment) Act 2008.
9. European Parliament and Council of the European Union, "General Data Protection Regulation (EU) 2016/679," Official Journal of the European Union L 119 (May 2016): 1–88, https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32016R0679.
10. European Parliament and Council of the European Union, "Directive (EU) 2022/2555 on Measures for a High Common Level of Cybersecurity across the Union (NIS2 Directive)," Official Journal of the European Union L 333 (December 2022): 80–152.
11. Cybersecurity and Infrastructure Security Agency (CISA), "Alert (AA20-352A): Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations," CISA, December 17, 2020, https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a.
12. National Institute of Standards and Technology, "Post-Quantum Cryptography: FIPS 203, 204, 205," NIST, August 2024, https://www.nist.gov/pqcrypto.
13. Andres Freund, "Backdoor in Upstream xz/liblzma Leading to SSH Server Compromise," OpenWall, March 29, 2024, https://www.openwall.com/lists/oss-security/2024/03/29/4.
14. International Organization for Standardization, "ISO/IEC 27037:2012 — Guidelines for Identification, Collection, Acquisition and Preservation of Digital Evidence," ISO, 2012.
15. National Institute of Standards and Technology, "Artificial Intelligence Risk Management Framework (AI RMF 1.0)," NIST AI 100-1, January 2023, https://doi.org/10.6028/NIST.AI.100-1.
16. Center for Internet Security, "CIS Controls Version 8," CIS, May 2021, https://www.cisecurity.org/controls/v8.
17. Ministry of Law and Justice, Government of India, "The Digital Personal Data Protection Act, 2023," Gazette of India Extraordinary Part II Section 1 (August 2023), https://www.meity.gov.in/content/digital-personal-data-protection-act-2023.
18. National Security Agency, "Quantum Computing and Post-Quantum Cryptography FAQs," NSA Cybersecurity, August 2021, https://media.defense.gov/2021/Aug/04/2002821837/-1/-1/1/Quantum_FAQs.PDF.
19. Gartner, "Market Guide for User and Entity Behavior Analytics," Gartner Research, December 2023.

END OF DOCUMENT — Framework v3.0 — April 2026